

6



Módulo 06

Proteção Web e Desenvolvimento Seguro

Aula 02

Ataques e Proteção Web – Parte 2

Introdução —

Nesta aula, você conhecerá os seguintes assuntos:

- Os ataques XSS e Directory Traversal attacks, sua identificação e prevenção;
- Os ataques XML, LDAP, SQL e Command Injection Attacks sua identificação e prevenção;
- Os ataques Server-Side Request Forgery (SSRF), sua identificação e prevenção.

Aula 6.2

Ataques e Proteção Web – Parte 2

Ataques na Web – Parte 2



CROSS-SITE SCRIPTING (XSS)

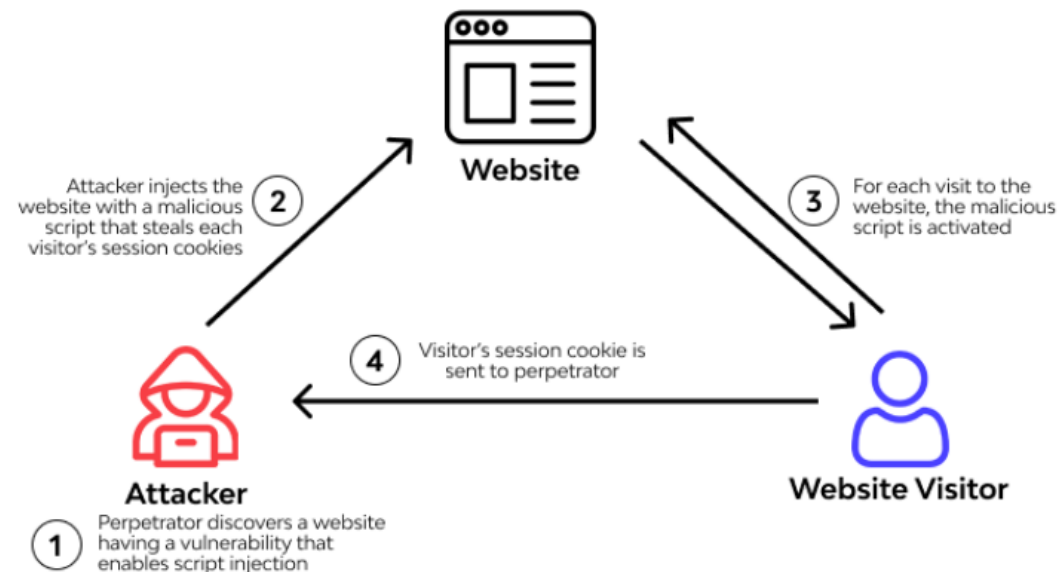
- Ocorre quando um atacante coloca scripts maliciosos em páginas web.
- O código malicioso é executado pelo navegador como se fosse parte legítima da página visualizada pelos usuários.
- Há três tipos principais de XSS:
 - 1 Refletido (Reflected XSS);
 - 2 Armazenado (Stored XSS);
 - 3 DOM-based (DOM-based XSS).

PREVENÇÃO E MITIGAÇÃO DE XSS

Práticas recomendadas para evitar ataques de XSS:

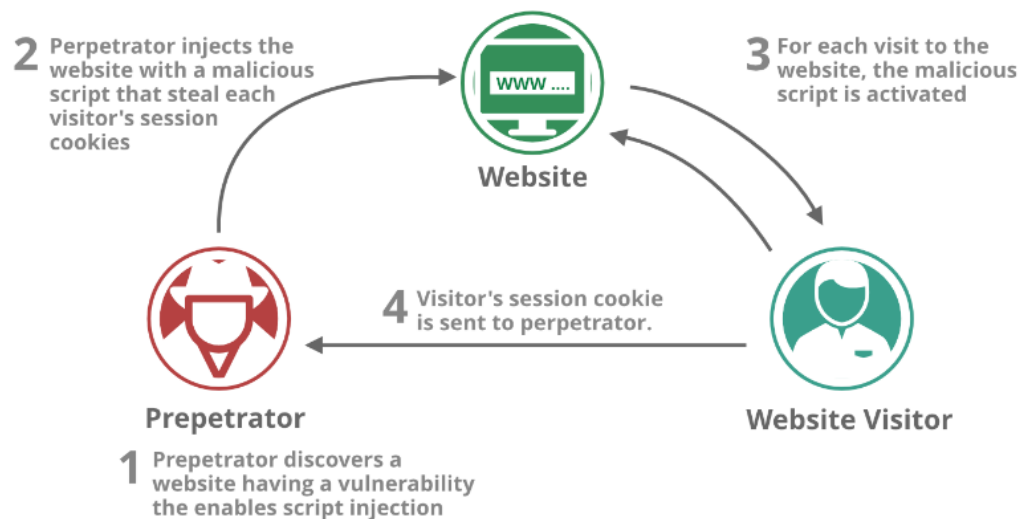
- 1 Validação de Entradas:
 - Filtragem Estrita;
 - Escape de Saída.
- 2 Utilização de Content Security Policy (CSP);
- 3 Sanitização de Dados;
- 4 Headers HTTP Seguros;

Stored cross-site scripting



Fonte: Quora.
Disponível em: <<https://www.quora.com/What-is-stored-cross-site-scripting>>.
Acesso em: 20 mar. 2024.

Reflected XSS



Fonte: Medium, 2020.
Disponível em: <<https://medium.com/@jenlindner22/the-risk-of-innerhtml-3981253fe217>>.
Acesso em: 20 mar. 2024.

PREVENÇÃO E MITIGAÇÃO DE XSS

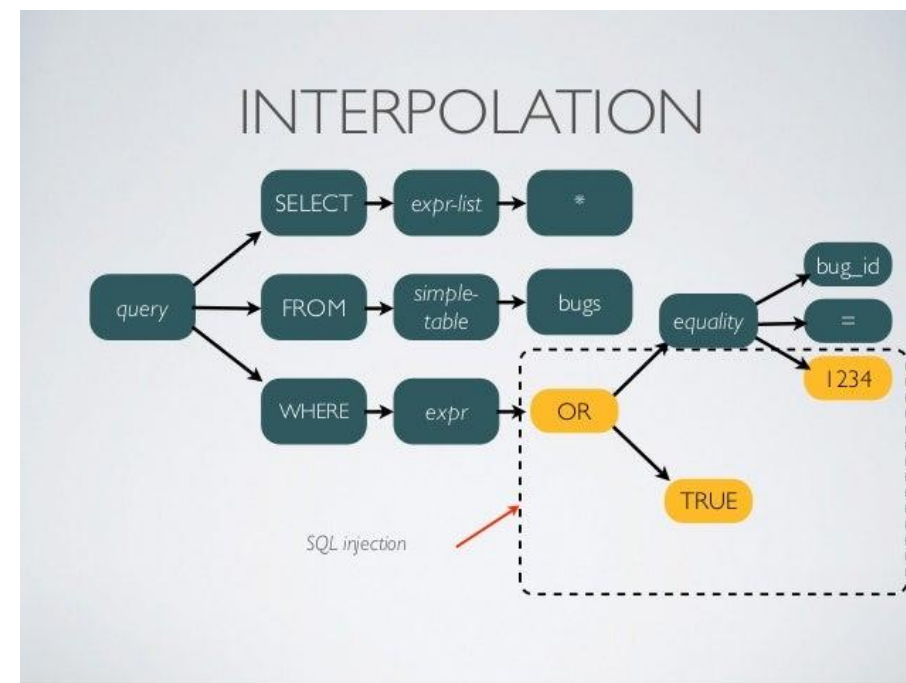
— Práticas recomendadas para evitar ataques de XSS (cont.):

- 5** Validação de Origem (Origin Validation);
- 6** Atenção a APIs e Bibliotecas de Terceiros;
- 7** Monitoramento e Teste;
- 8** Treinamento e Conscientização;
- 9** Utilização de Frameworks Seguros.

STRUCTURED QUERY LANGUAGE INJECTION ATTACKS (SQL INJECTION)

- Trata-se da inserção de instruções SQL maliciosas em formulários de entrada.
- Visa manipular consultas SQL executadas pelo aplicativo invadido.
- Passos dos ataques de SQL Injection:

- 1 Identificação de Vulnerabilidades;
- 2 Inserção de Instruções Maliciosas;
- 3 Execução da Instrução Maliciosa;
- 4 Exploração do Resultado.



Fonte: Tureba, 2020.
Disponível em: <<https://tureba.org/postgresql-sqlinjection.html>>.
Acesso em: 21 mar. 2024.



PREVENÇÃO E MITIGAÇÃO DE SQL INJECTION

— Medidas de prevenção e mitigação do SQL Injection:

- 1 Validação de Entradas;
- 2 Consultas Parametrizadas;
- 3 Evite Construção de Consulta Manual;
- 4 Princípio do Menor Privilégio;
- 5 Monitoramento e Registros de Auditoria.

XML INJECTION ATTACK

- Ocorre quando dados não confiáveis são inseridos em documentos XML.
- O analisador XML interpreta os dados que pode levar a resultados indesejados.
- Os seguintes passos descrevem um cenário comum de ataque:

- 1 Identificação da Vulnerabilidade;
- 2 Inserção de Dados Maliciosos;
- 3 Interpretação Incorreta.

How an XML Injection Attack Works



Fonte: The SSL Store, 2022.

Disponível em: <<https://www.thesslstore.com/blog/xml-injection-attacks-what-to-know-about-xpath-xquery-xxe-more/>>.

Acesso em: 21 mar. 2024.

PREVENÇÃO E MITIGAÇÃO DE SQL INJECTION

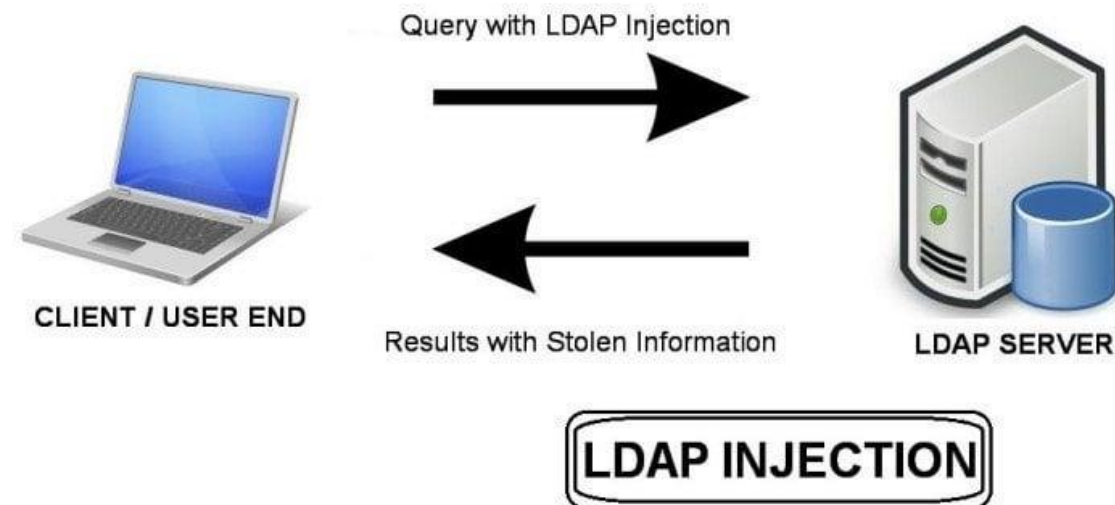
— Medidas de prevenção e mitigação de XML Injection:

- 1 Validação de Entrada;
- 2 Filtragem de Dados;
- 3 Evitar a Concatenação de Dados em Documentos XML;
- 4 Uso de Bibliotecas Seguras;
- 5 Limitar Privilégios;
- 6 Monitoramento e Registros;
- 7 Treinamento e Conscientização;
- 8 Atualizações Regulares.

LIGHTWEIGHT DIRECTORY ACCESS PROTOCOL (LDAP) INJECTION ATTACK

- Ocorre quando dados não confiáveis são inseridos em consultas LDAP.
- O invasor pode manipular as consultas para acessar, modificar ou excluir informações armazenadas em um diretório LDAP.
- Os passos típicos de um ataque de LDAP Injection incluem:

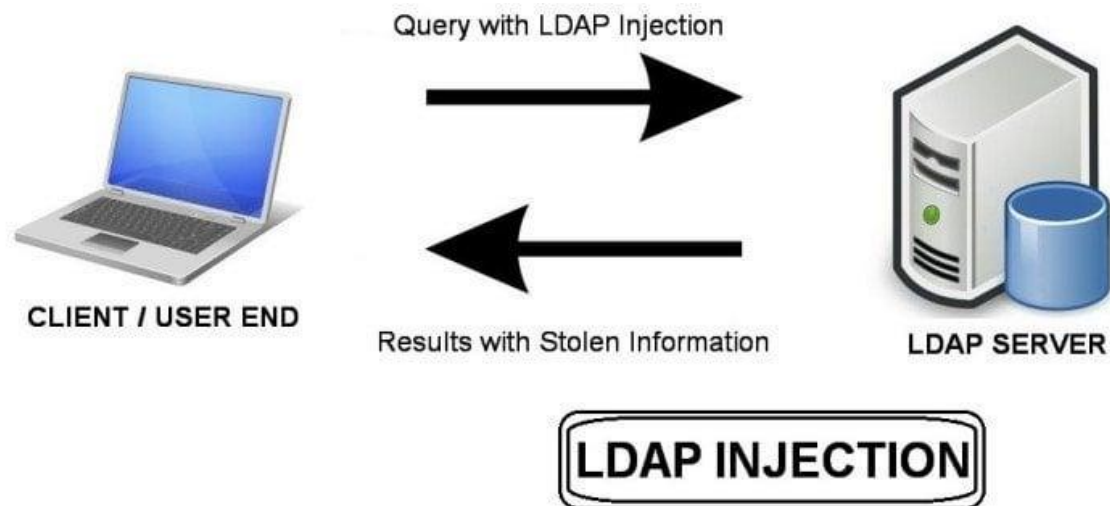
- 1 Identificação da Vulnerabilidade;
- 2 Inserção de Dados Maliciosos;
- 3 Manipulação da Consulta LDAP;
- 4 Execução de Consulta Maliciosa.



Fonte: Reddit, 2016.

Disponível em: <https://www.reddit.com/r/hacking/comments/43qb31/what_is_ldap_injection_attack_and_how_does_it_work/?rdt=3807>.

Acesso em: 21 mar. 2024.



Fonte: Reddit, 2016.

Disponível em: <https://www.reddit.com/r/hacking/comments/43qb31/what_is_ldap_injection_attack_and_how_does_it_work/?rdt=3807>.

Acesso em: 21 mar. 2024.

PREVENÇÃO E MITIGAÇÃO DE SQL INJECTION

— Abordagem de prevenção:

- 1 Consultas LDAP Parametrizadas;
- 2 Filtros de Pesquisa Seguros;
- 3 Validação de Entrada;
- 4 Escape de Caracteres Especiais;
- 5 Princípio do Menor Privilégio;
- 6 Monitoramento e Registros de Log;
- 7 Treinamento e Conscientização;
- 8 Atualizações Regulares.

DIRECTORY TRAVERSAL

- Ocorre quando um invasor descobre uma vulnerabilidade em path de arquivo ou diretório em um aplicativo web.
- Passos de um ataque de Directory Traversal:
 - 1 Identificação da Vulnerabilidade;
 - 2 Inserção de Caminho Manipulado;
 - 3 Acesso aos Arquivos/Diretórios.



PREVENÇÃO E MITIGAÇÃO DE DIRECTORY TRAVERSAL

— Medidas de prevenção e mitigação de Directory Traversal:

- 1 Validação Estrita;
- 2 Utilização de Caminhos Relativos;
- 3 Restrições de Acesso;
- 4 Sanitização de Caminhos;
- 5 Listas de Permissões (Whitelists);
- 6 Limitação de Caracteres Especiais.

COMMAND INJECTION ATTACKS

- Trata-se da inserção indevida de comandos maliciosos em campos de entrada ou parâmetros de aplicativo web.
- Os comandos são executados no sistema operacional da máquina.
- Passos do Command Injection Attack:
 - 1 Identificação da Vulnerabilidade;
 - 2 Inserção de Comandos Maliciosos;
 - 3 Execução do Comando Malicioso;
 - 4 Exploração.



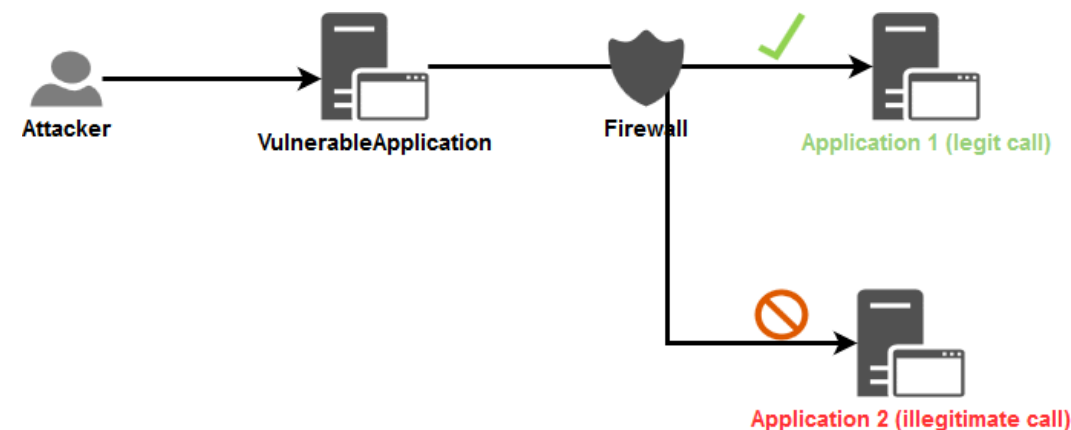
PREVENÇÃO E MITIGAÇÃO DE COMMAND INJECTION

— Medidas de prevenção de
Command Injection:

- 1 Validação Estrita;
- 2 Utilização de Funções Seguras;
- 3 Sanitização de Dados;
- 4 Restrições de Privilégios;
- 5 Uso de Entrada de Usuário Segura.

SERVER-SIDE REQUEST FORGERY (SSRF)

- O Forjamento de Requisições do Lado do Servidor (SSRF) é um ataque onde um servidor executa requisições não autorizadas em outros recursos.
- Etapas de um típico de ataque de SSRF:
 - 1 Identificação da Vulnerabilidade;
 - 2 Inserção de URL Manipulada;
 - 3 Execução da Requisição;
 - 4 Exploração.



Fonte: OWASP Cheat Sheet Series.
Disponível em: <https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html>.
Acesso em: 21 mar. 2024.

PREVENÇÃO E MITIGAÇÃO DE SSRF

— Medidas de prevenção e mitigação de SSRF:

- 1 Validação Estrita de Entradas;
- 2 Uso de Listas de Permissões (Whitelists);
- 3 Limitação de Privilégios;
- 4 Restrição de Saída de Rede;
- 5 Utilização de URLs Relativas;
- 6 Monitoramento de Logs.

SERVER - SIDE REQUEST FORGERY (SSRF)



Fonte: Medium, 2021.

Disponível em: <<https://rodolfomarianocy.medium.com/ssrf-entenda-o-b%C3%A1sico-de-forma-simples-e-algumas-formas-de-bypass-e694751acc0e>>.

Acesso em: 21 mar. 2024.

6



Você chegou ao final da Aula 02
Ataques e Proteção Web
– Parte 2